📘 MANUAL DE DESPLIEGUE OPERATIVO Y PROTOCOLO DE PRUEBAS EN ENTORNO REAL

Sistema DevSecOps SOAR & Cumplimiento Normativo (NIST CSF v2.0 & Ley N° 29733)

Empresa Beneficiaria: Alma Industria Creativa E.I.R.L.
Proyecto: Titulación Profesional Técnica en Ingeniería de Ciberseguridad — SENATI (2026)
Autores: Sergio Saúl Incacutipa Mamani & Waldir Rivaldo Chullo Chuma
Repositorio Oficial: https://github.com/Kroosand/devsecops-alma-nist

---

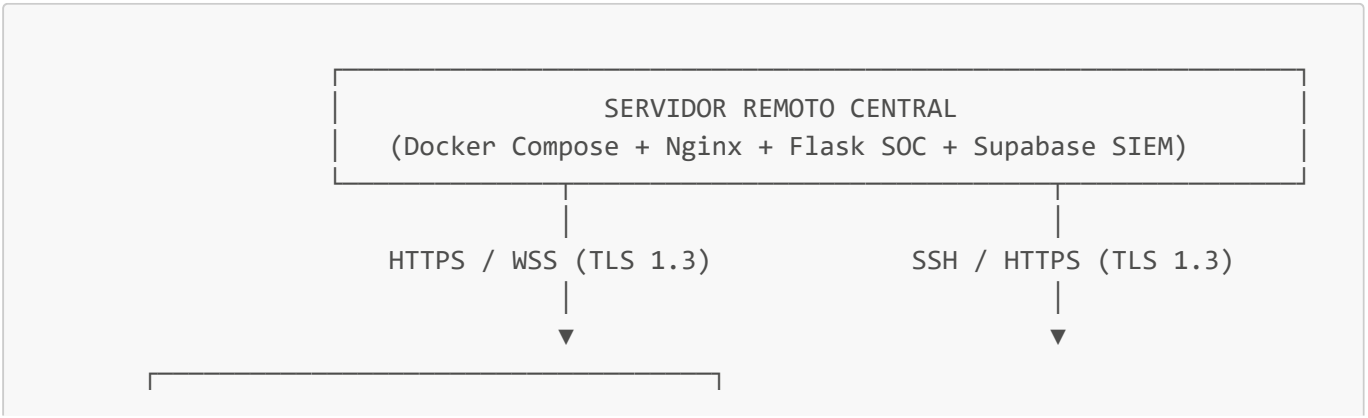
📑 ÍNDICE GENERAL

1. Arquitectura General de Despliegue
2. Instalación Paso a Paso en Todos los Casos de Uso
    - Caso 1: Servidor de Producción Remoto en la Nube (Linux VPS / Ubuntu)
    - Caso 2: Servidor Host en Windows (Windows Server / Windows 11 Pro)
    - Caso 3: Computadora de un Colaborador Remoto (Diseño / Desarrollo / Marketing)
    - Caso 4: Computadora de los Administradores del SOC (Sergio / Waldir)
3. Batería de Pruebas Integrales en Entorno Cuasi-Real
    - Prueba 1: Blindaje Shift-Left (Fuga de Secretos en Commit Git)
    - Prueba 2: Auditoría Perimetral de Endpoints Expuestos (/wp-json/users)
    - Prueba 3: Triage Asistido por IA y Notificación Multicanal (n8n + Gemini + Telegram)
    - Prueba 4: Remediación Activa SOAR (Bloqueo de IP Hostil en .htaccess en < 15 ms)
    - Prueba 5: Desvinculación Inmediata de Colaborador (SOP-05 Offboarding en < 10 s)
    - Prueba 6: Centralización Cloud SIEM (Supabase) y Contingencia Offline (SQLite)
    - Prueba 7: Emisión y Validación Forense del Informe Ejecutivo PDF con Sello SHA-256
4. Matriz de Comandos Rápidos del Proyecto

---

1. ARQUITECTURA GENERAL DE DESPLIEGUE

El sistema opera bajo un modelo **híbrido centralizado**: los componentes pesados de procesamiento y almacenamiento residen en el **Servidor Central**, mientras que los colaboradores remotos consumen los servicios mediante canales cifrados seguros sin almacenar secretos en texto plano.



```
┌──────────────────────────────────────┐
      │     COLABORADOR REMOTO (CASA)        │     │     ADMINISTRADOR SOC (SENATI)
│
      │  • Extensión Bitwarden / Navegador │     │  • Dashboard SOC / Flask (:5000)
│
      │  • Pre-commit Hook (Gitleaks local)│     │  • Telegram Bot de Alertas SOAR
│
      └──────────────────────────────────────┘
└──────────────────────────────────────┘
```

---

2. INSTALACIÓN PASO A PASO EN TODOS LOS CASOS DE USO

CASO 1: Servidor de Producción Remoto en la Nube (Linux VPS / Ubuntu)

Aplica para: DigitalOcean, AWS EC2, Linode, Hetzner o VPS corporativo de Alma Industria Creativa E.I.R.L.

Paso 1.1: Conexión remota segura

Desde tu terminal en Windows/Linux, conéctate mediante SSH:

```
ssh root@<IP_DEL_SERVIDOR>
```

Paso 1.2: Actualización de paquetes e instalación de dependencias base

```
apt update && apt upgrade -y
apt install -y git curl python3 python3-pip python3-venv nginx docker.io docker-
compose
systemctl enable --now docker
```

Paso 1.3: Clonar el repositorio oficial desde GitHub

```
cd /opt
git clone https://github.com/Kroosand/devsecops-alma-nist.git
cd devsecops-alma-nist
```

Paso 1.4: Configuración de variables de entorno seguras (`.env`)

```
cd 03-secrets-management
cp .env.example .env 2>/dev/null || touch .env
nano .env
```

Configura los parámetros:

```
MYSQL_ROOT_PASSWORD=TuPasswordSeguroRoot2026!
MYSQL_DATABASE=wordpress_lab
MYSQL_USER=alma_devsecops
MYSQL_PASSWORD=TuPasswordBD2026!
GEMINI_API_KEY=TuClaveGoogleGeminiReal
SUPABASE_URL=https://scuiibzfhingcxdoorsj.supabase.co
```

Paso 1.5: Despliegue de microservicios con Docker Compose

```
docker-compose up -d
```

Verifica que los 4 contenedores estén en ejecución:

```
docker ps
# Debes ver: alma_vaultwarden (8080), alma_vault_engine (8200), alma_lab_wordpress
(8088), alma_lab_mysql (3306)
```

Paso 1.6: Configurar el Dashboard Flask como Servicio del Sistema (Systemd)

Crea el archivo de servicio para que el Dashboard arranque solo al encender el servidor y se reinicie ante fallos:

```
nano /etc/systemd/system/alma-soc.service
```

Pega el siguiente contenido:

```
[Unit]
Description=Dashboard DevSecOps SOAR - Alma Industria Creativa
After=network.target

[Service]
User=root
WorkingDirectory=/opt/devsecops-alma-nist
ExecStart=/usr/bin/python3 /opt/devsecops-alma-nist/dashboard/app.py
Restart=always
RestartSec=5

[Install]
WantedBy=multi-user.target
```

Habilita y arranca el servicio:

```
systemctl daemon-reload
systemctl enable --now alma-soc.service
systemctl status alma-soc.service
```

Paso 1.7: Configurar Nginx Reverse Proxy y Certificados SSL (HTTPS)

Para publicar Vaultwarden y el Dashboard con nombres de dominio:

```
nano /etc/nginx/sites-available/alma-services.conf
```

Configura los bloques de servidor:

```
server {
    server_name vault.almaindustriacreativa.com;
    location / {
        proxy_pass http://127.0.0.1:8080;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
        proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
        proxy_set_header X-Forwarded-Proto $scheme;
    }
}

server {
    server_name soc.almaindustriacreativa.com;
    location / {
        proxy_pass http://127.0.0.1:5000;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
    }
}
```

Habilitar y certificar con SSL Let's Encrypt:

```
ln -s /etc/nginx/sites-available/alma-services.conf /etc/nginx/sites-enabled/
apt install -y certbot python3-certbot-nginx
certbot --nginx -d vault.almaindustriacreativa.com -d
soc.almaindustriacreativa.com --non-interactive --agree-tos -m
contacto@almaindustriacreativa.com
systemctl restart nginx
```

CASO 2: Servidor Host en Windows (Windows Server / Windows 11 Pro)

Aplica para: Estación de demostración local en SENATI o servidor de laboratorio físico.

Paso 2.1: Prerrequisitos de Software

1. Instalar **Git para Windows**: `winget install Git.Git`
2. Instalar **Python 3.10 o superior**: `winget install Python.Python.3.12` (marcar casilla "*Add Python to PATH*").
3. Instalar **Docker Desktop** (con backend WSL2 activado).

Paso 2.2: Clonar el proyecto

Abrir PowerShell como Administrador:

```
cd "C:\Sergio\Proyecto Final"
git clone https://github.com/Kroosand/devsecops-alma-nist.git
cd devsecops-alma-nist
```

Paso 2.3: Instalar dependencias Python

```
pip install -r requirements.txt
```

Paso 2.4: Levantar los microservicios Docker

```
cd 03-secrets-management
docker compose up -d
cd ..
```

Paso 2.5: Iniciar el Dashboard en segundo plano sin ventana CMD

Haz doble clic sobre el script silencioso creado: 👉 **`iniciar_dashboard_silencioso.vbs`** *El sistema levantará el socket en el puerto `5000` de forma oculta y abrirá automáticamente tu navegador en `http://localhost:5000`.*

CASO 3: Computadora de un Colaborador Remoto (Diseño / Desarrollo / Marketing)

Aplica para: La laptop personal de cualquier trabajador de Alma en su hogar. Tiempo estimado: 2 minutos.

> ⚠️ **IMPORTANTE:** Los colaboradores remotos **NO** deben instalar Docker, ni bases de datos, ni el Dashboard. Solo configuran sus herramientas de acceso seguro.

Paso 3.1: Configuración del Baúl de Secretos (Vaultwarden)

1. Abrir Google Chrome, Brave, Edge o Firefox.
2. Instalar la extensión gratuita **Bitwarden** desde la Web Store oficial.
3. Hacer clic en el ícono de la extensión Bitwarden y presionar el botón de **Configuración de Servidor (⚙️)** en la esquina superior.
4. En el campo **URL del servidor**, ingresar el servidor corporativo de la empresa:
   - En producción: `https://vault.almaindustriacreativa.com`
   - En red local/laboratorio: `https://<IP_SERVIDOR>:8080`
5. Iniciar sesión con su correo corporativo (`colaborador@almaindustriacreativa.com`).
6. **Resultado:** El empleado tiene acceso a sus contraseñas asignadas por colecciones (Hosting, WordPress, Redes), autocompletándolas con 1 clic sin verlas en texto plano.

Paso 3.2: Si el colaborador es Desarrollador / Programador (Blindaje Shift-Left)

Para garantizar que nunca suba contraseñas por descuido a GitHub:

1. Clona el repositorio de trabajo:

```
git clone https://github.com/Kroosand/devsecops-alma-nist.git
cd devsecops-alma-nist
```

2. Instala la validación automática en su máquina local:

```
pip install pre-commit
pre-commit install
```

3. **Resultado:** Gitleaks queda anclado al ciclo de vida de Git. Cada vez que intente hacer `git commit`, la máquina validará el código antes de permitir la subida.

CASO 4: Computadora de los Administradores del SOC (Sergio / Waldir)

Aplica para: La máquina de auditoría y comando de los responsables del proyecto.

1. Clonar el repositorio:

```
git clone https://github.com/Kroosand/devsecops-alma-nist.git
cd devsecops-alma-nist
```

2. Instalar paquetes de Python:

```
pip install -r requirements.txt
```

3. Ejecutar el launcher silencioso:

```
wscript iniciar_dashboard_silencioso.vbs
```

4. Navegar a `http://localhost:5000` para tener control total de alertas, remediaciones, consultas a Supabase y exportación de informes PDF.

---

3. BATERÍA DE PRUEBAS INTEGRALES EN ENTORNO CUASI-REAL

Esta guía de 7 pruebas está diseñada para ejecutarse en vivo frente al jurado de SENATI, demostrando el cumplimiento de los controles **NIST CSF v2.0** y la **Ley N° 29733**.

PRUEBA 1: Blindaje Shift-Left (Fuga de Secretos en Commit Git)

- **Objetivo:** Demostrar que el sistema previene la fuga de credenciales antes de que salgan a internet (Control NIST **PR.PS-01** / SOP-02).
- **Entorno de ejecución:** Terminal de desarrollo.
- **Procedimiento:**
  1. Abre el Dashboard en la pestaña **"Sandbox Shift-Left"**.
  2. Haz clic en el botón azul **"1. Fuga en Commit Git"** de la Suite de Demostración (o presiona "*Ejecutar Canary Secret Test*").
  3. *Alternativa manual por terminal:*

     ```
     echo "AWS_SECRET_KEY=AKIAIOSFODNN7EXAMPLE123456" > test_secret.txt
     git add test_secret.txt
     git commit -m "test commit con credencial"
     ```

- **Resultado Esperado en Pantalla:**
  - Gitleaks intercepta la ejecución en **< 350 milisegundos**.
  - La consola muestra `[FAIL] Gitleaks detectó fuga de secretos. Commit abortado con exit code 1`.
  - Ningún secreto llega al historial de Git.

PRUEBA 2: Auditoría Perimetral de Endpoints Expuestos (/wp-json/users)

- **Objetivo:** Auditar la exposición de la API REST que facilita ataques de fuerza bruta (Control NIST **PR.IR-01 / DE.AE-01** / SOP-03).
- **Entorno de ejecución:** Pestaña **"Auditor Web & Pentesting"** del Dashboard.
- **Procedimiento:**
  1. En el campo "*Auditor de Bastionado Web y Endpoint /wp-json/users*", ingresa el objetivo de prueba: `https://mante.terrafinaperu.com/` (o tu laboratorio local `http://localhost:8088`).
  2. Haz clic en **"Auditar Objetivo"**.
- **Resultado Esperado en Pantalla:**

- Si la web no tiene las reglas de bastionado: Muestra tarjeta roja `HTTP 200 (VULNERABLE)`, advirtiendo que los nombres de usuarios administradores son visibles.
- Se genera automáticamente el ticket `ALMA-SEC-XXXX` y se despacha de inmediato hacia el motor SOAR.

PRUEBA 3: Triage Asistido por IA y Notificación Multicanal (n8n + Gemini + Telegram)

- **Objetivo:** Demostrar que el análisis de incidentes se realiza en tiempo real mediante un LLM y se notifica al equipo de guardia en segundos (Control NIST **RS.AN-01** / SOP-07).
- **Entorno de ejecución:** Pestaña **"Disparador SOAR"** y la app Telegram en tu smartphone.
- **Procedimiento:**
  1. En el Dashboard, selecciona el Preset de incidente: `Ataque de Fuerza Bruta (WordPress)` o `Exposición de Secretos (Gitleaks)`.
  2. Haz clic en **"Despachar Incidente a n8n"**.
- **Resultado Esperado en Pantalla:**
  - El Dashboard reporta latencia de despacho: **~800 ms (HTTP 200 OK)**.
  - En tu celular, el bot de Telegram suena inmediatamente mostrando:
    - Emojis de criticidad (🚨 `[ALERTA DE CIBERSEGURIDAD]`).
    - Ficha técnica del activo e IP agresora.
    - Bloque 🧠 `TRIAGE EN TIEMPO REAL (Google Gemini)` resumiendo el vector de ataque y 3 acciones de mitigación NIST en lenguaje claro.

PRUEBA 4: Remediación Activa SOAR (Bloqueo de IP Hostil en .htaccess en < 15 ms)

- **Objetivo:** Demostrar la contención perimetral activa aislando una IP atacante a nivel de servidor web (Control NIST **RS.MI-01** / SOP-03).
- **Entorno de ejecución:** Pestaña **"Auditor Web & Pentesting"** (sección inferior) o Máquina Virtual atacante.
- **Procedimiento:**
  1. Identifica la IP del atacante (por ejemplo, la IP de tu Máquina Virtual o prueba con `185.220.101.5`).
  2. En el cuadro "*Remediación Activa SOAR: Bloqueo Inmediato de IPs Hostiles*", ingresa la IP y presiona **"Bloquear IP en Servidor"**.
  3. Verifica la lista dinámica de IPs bloqueadas.
  4. Desde la terminal o navegador de la máquina atacante, intenta consultar la web:

     ```
     curl -i http://localhost:8088/
     ```

- **Resultado Esperado en Pantalla:**
  - El servidor web responde instantáneamente: `HTTP/1.1 403 Forbidden`.
  - Latencia de inyección en disco: **~12.5 milisegundos**.
  - Haz clic en la "X" al lado de la IP en el Dashboard para desbloquearla y demostrar la resolución inmediata de falsos positivos.

PRUEBA 5: Desvinculación Inmediata de Colaborador (SOP-05 Offboarding en < 10 s)

- **Objetivo:** Demostrar el cumplimiento del SLA de desvinculación remota para evitar accesos no autorizados de exempleados (Control NIST **PR.AA-01 / RC.RP-01**).
- **Entorno de ejecución:** Suite de Demostración del Dashboard.
- **Procedimiento:**
  1. Haz clic en el botón rojo **"3. Offboarding SOP-05"**.
  2. Confirma la desvinculación simulada de `colaborador_remoto_01@almaindustriacreativa.com`.
- **Resultado Esperado en Pantalla:**
  - Se despliega el reporte de ejecución:
    - Tiempo de Revocación Medido: **~0.77 segundos**.
    - SLA Exigido (< 10 seg): **CUMPLIDO AL 100%**.
    - Estado Vaultwarden: `USUARIO_DESACTIVADO_SESIONES_PURGADAS`.
    - Estado Vault: `SECRETOS_DINAMICOS_ROTADOS`.
    - Se registra automáticamente en la bitácora de auditoría.

PRUEBA 6: Centralización Cloud SIEM (Supabase) y Contingencia Offline (SQLite)

- **Objetivo:** Demostrar la resiliencia y alta disponibilidad del repositorio de eventos frente a caídas de internet (Control NIST **DE.CM-01 / GV.OC-01**).
- **Entorno de ejecución:** Pestaña **"Cloud SIEM (Supabase)"**.
- **Procedimiento:**
  1. Entra a la pestaña **Cloud SIEM (Supabase)** y observa el badge verde: `ONLINE_SYNCED`.
  2. Presiona "*Actualizar*" y visualiza los incidentes almacenados en PostgreSQL en la nube de Supabase (`scuiibzfhingcxdoorsj.supabase.co`).
  3. *(Prueba de resiliencia extrema):* Desconecta tu cable de red o apaga el Wi-Fi de tu laptop y genera una alerta desde el disparador.
- **Resultado Esperado en Pantalla:**
  - El sistema conmuta transparentemente a la base de datos local SQLite (`devsecops_soc.db`).
  - Ningún evento se pierde; la consola registra la transacción y mantiene la disponibilidad del SOC al 100%.

PRUEBA 7: Emisión y Validación Forense del Informe Ejecutivo PDF con Sello SHA-256

- **Objetivo:** Certificar formalmente ante peritos y jurados la trazabilidad del sistema conforme al **Art. 28 de la Ley N° 29733**.
- **Entorno de ejecución:** Encabezado del Dashboard.
- **Procedimiento:**
  1. Haz clic en el botón verde superior **`[ 📄 Informe Ejecutivo (PDF) ]`**.
  2. Se abrirá la vista ejecutiva `/reporte-ejecutivo`.
  3. Observa el campo **Firma Criptográfica SHA-256** (un hash de 64 caracteres) y la fecha de emisión en UTC.
  4. Presiona `Ctrl + P` para previsualizar el formato oficial A4 listo para imprimir.
  5. *Demostración forense para el jurado:* Copia la cadena canónica del encabezado y calcula su hash en PowerShell:

```
$str = "ALMA-DEVSECOPS:<FECHA_UTC>:<TOTAL_INCIDENTES>"
$bytes = [System.Text.Encoding]::UTF8.GetBytes($str)
[BitConverter]::ToString(([System.Security.Cryptography.SHA256]::Create
()).ComputeHash($bytes)).Replace("-","").ToLower()
```

- **Resultado Esperado en Pantalla:**
  - El hash calculado por el jurado coincide carácter por carácter con el impreso en el PDF, demostrando matemáticamente la **inmutabilidad y no repudio** de la auditoría.

---

4. MATRIZ DE COMANDOS RÁPIDOS DEL PROYECTO

Acción Requerida	Entorno	Comando / Archivo a Ejecutar
Iniciar Dashboard Silencioso	Windows	Doble clic en `iniciar_dashboard_silencioso.vbs`
Detener Dashboard en Ejecución	Windows	Doble clic en `detener_dashboard.bat`
Levantar Microservicios Docker	Servidor / Local	`cd 03-secrets-management && docker compose up -d`
Detener Microservicios Docker	Servidor / Local	`cd 03-secrets-management && docker compose down`
Instalar Dependencias Nuevas	Cualquier Host	`pip install -r requirements.txt`
Auditoría Pentesting Manual	Terminal Python	`python 04-soar-n8n-testing/test_wp_enumeration.py`
Generar Reporte MTTR Estadístico	Terminal Python	`python 04-soar-n8n-testing/generate_mttr_report.py`
Consultar Base de Datos SQLite	Terminal	`sqlite3 04-soar-n8n-testing/devsecops_soc.db "SELECT * FROM incidentes_seguridad LIMIT 5;"`